



VULNERABILITY RISK ASSESSMENT



AUGUST 20, 2025
AYDEN ROMULUS

Table of Contents

Introduction.....	3
Executive Summary	4
Vulnerability Analysis.....	5
FileZilla FTP Server Multiple DoS Vulnerabilities	5
Severity.....	5
Description	5
Impact.....	5
Risks.....	5
Affected Assets.....	5
Sources	6
FileZilla Server versions before Version 0.9.31 DoS	6
Severity.....	6
Description	6
Impact.....	6
Risks.....	6
Affected Assets.....	6
Sources	7
SSL Medium Strength Cipher Suites (SWEET32)	7
Severity.....	7
Description	7
Impact.....	7
Risks.....	7
Affected Assets.....	7
Sources	7
TLS Version 1.0 Protocol Detection	8
Severity.....	8
Description	8
Impact.....	8

Risks.....	8
Affected Assets.....	8
Sources	8
PHP Outdated Version (Version 7.3.21).....	9
Severity.....	9
Description	9
Impact.....	9
Risks.....	9
Affected Assets.....	9
Sources	9
Risk Matrix.....	10
Justification for Likelihood and Impact Scores	11
FileZilla FTP Server Multiple DoS Vulnerabilities (CVE-2005-0851).....	11
FileZilla Server < 0.9.31 DoS (CVE-2009-0884).....	12
RPD Weak SSL Cipher – SWEET32 (CVE-2016-2183).....	12
TLS 1.0 Protocol Support (Deprecated)	13
PHP 7.3.21 Outdated (CVE-2020-7069 / 7070)	14
Asset-Based Summary	15
References.....	17

Introduction

This document identifies and evaluates security vulnerabilities within an organization utilizing a generated vulnerability scan report and the risks they present to critical assets. This assessment will comprise of three main components: Vulnerability Analysis, Risk Matrix, and Asset Summary. Sections will analyze vulnerability scan data, details of identified vulnerabilities, and perform a risk assessment on essential organizational assets.

Executive Summary

Overall, in the risk assessment, the Tenable scan highlights that the Windows server (10.13.30.105) is the most at risk. Weak encryption (SWEET32, TLS 1.0/1.1) is currently being run on the Remote Desktop service, making private sessions vulnerable to interception.

Additionally, its FileZilla FTP service is using an older version that is susceptible to denial-of-service attacks which might give threat actors the ability to interrupt file transfers whenever they wish to.

Also, the web server (10.13.26.211) runs an outdated PHP version (7.3.21), leaving it exposed to known vulnerabilities, though a lower risk level compared to the RDP/FTP issues.

It is recommended that the Windows server is immediately hardened by disabling TLS 1.0/1.1 and 3DES cipher suites. Additionally, require that TLS 1.2 or above is utilized with modern AES-GCM suites. Lastly, upgrade or discontinue use of FileZilla FTP; migrate to SFTP/FTPS only.

It is also recommended that the Web Server stack is modernized by upgrading PHP to version 8.x (a supported branch). Apache/PHP dependencies should be regularly patched, and a patch management policy should be implemented to comply with known frameworks (NIST CSF, ISO 27001).

Vulnerability Analysis

FileZilla FTP Server Multiple DoS Vulnerabilities

Severity

The Common Vulnerability Scoring System (CVSS) rates this vulnerability severity as a 7.8 which is considered high.

Description

FileZilla is a free and open-source, cross-platform File Transfer Protocol (FTP) application for both clients and servers. This particular version currently in use can experience slowdowns or crashes if threat actors send maliciously crafted requests. For example, requesting files with reserved names like “CON” or enabling compression in certain ways.

Impact

A threat actor could make the server unavailable by forcing it to slow down and disrupt services like file transfers.

Risks

This could be used as a Denial of Service (DoS) attack, preventing users from uploading or downloading files.

Affected Assets

The file server is currently running FileZilla FTP on 10.13.30.105 (TCP/21)

Sources

The information on this vulnerability was made possible on the National Institute of Standards and Technology's (NIST) website via the National Vulnerability Database (NVD). The resource on this vulnerability is [CVE-2005-0851](#) (National Institute of Technology and Standards, 2024).

FileZilla Server versions before Version 0.9.31 DoS

Severity

The CVSS rates this vulnerability severity as a 5.0 which is considered to be high.

Description

This vulnerability involves an outdated FileZilla server version which has a flaw with Secure Sockets Layer (SSL) handling. SSL is a security protocol that provides encryption and authentication for communication over the internet. As a certificate, it allows for securely establishing connections between web browsers and servers. With this in mind, threat actors can crash the server remotely or even eavesdrop if the proper controls are not in effect.

Impact

This makes the FTP service unreliable and vulnerable to crashes.

Risks

This could cause downtime and exploitation of outdated SSL code.

Affected Assets

The same FileZilla FTP server referenced previously, has this vulnerability (10.13.30.105, TCP/21).

Sources

The information on this vulnerability was made possible on the NIST's website via the NVD. The resource on this vulnerability is [CVE-2009-0884](#) (National Institute of Technology and Standards, 2024b).

SSL Medium Strength Cipher Suites (SWEET32)

Severity

The CVSS rates this vulnerability severity as a 7.5 which is categorized to be high.

Description

The server allows for weak SSL encryption which uses the 3DES cipher. Threat actors can potentially decrypt secure traffic if they capture enough data. This attack is known as SWEET32.

Impact

Sensitive data could be exploited such as usernames, passwords, or files transferred over Remote Desktop Protocol or SSL.

Risks

Makes it easier for threat actors to spy on communications between clients and servers.

Affected Assets

The RDP service running on 10.13.30.105 (TCP/3389) can be affected by this vulnerability.

Sources

The information on this vulnerability was made possible via the Sweet32 website and the Common Vulnerabilities and Exposures (CVE) database. The resources on this vulnerability are

[CVE-2016-2183](#) and [CVE-2016-6329](#) (Bhargavan & Leurent, n.d.; Common Vulnerabilities and Exposures, 2016; Common Vulnerabilities and Exposures, 2017).

TLS Version 1.0 Protocol Detection

Severity

The CVSS rates this vulnerability severity as a 6.5 which is categorized to be medium.

Description

The server supports TLS 1.0, which is an outdated encryption protocol with known weaknesses. Modern systems use 1.2 or 1.3 which are up-to-date versions of TLS.

Impact

This could allow attackers to break encryption and intercept communications as this version is no longer being patched for vulnerabilities. Also, security frameworks like the Payment Card Industry and Data Security Standard (PCI DSS) forbid the continued use of TLS 1.0.

Risks

Risks include failure to comply with existing compliance standards like PCI DSS, HIPAA, ISO 27001, and more attack surfaces for threat actors to exploit.

Affected Assets

The RDP service running on 10.13.30.105 (TCP/3389) can be affected by this vulnerability.

Sources

Information on this vulnerability was made possible via documentation surrounding the deprecation of TLS 1.0 (Moriarty & Farrell, 2021).

PHP Outdated Version (Version 7.3.21)

Severity

The CVSS rates this vulnerability severity as a 6.5 (listed on Tenable as medium) but can be categorized as low.

Description

This PHP version is outdated and vulnerable to several known issues.

Impact

Attackers could exploit flaws in how this version of PHP processes code, potentially causing information disclosure or other unexpected behavior.

Risks

Risks could include threat actors exploiting weaknesses via server-side code execution if the web application relies on this outdated PHP version.

Affected Assets

The web server on 10.13.26.211 (TCP/80, Apache, and PHP) can be affected by this vulnerability.

Sources

The information on this vulnerability was made possible on NIST's website via the NVD. The resources on this vulnerability are [CVE-2020-7069](#) and [CVE-2020-7070](#) (National Institute of Technology and Standards, 2020a; National Institute of Technology and Standards, 2020b).

Risk Matrix

Below is a risk matrix table of the five vulnerabilities identified from the Tenable scan evaluating the likelihood and impact of threats to the identified assets. The risk scoring formula will be used [Likelihood (1-5) * Impact (1-5)].

Vulnerability	Likelihood (1 – 5)	Impact (1 -5)	Risk Score	Severity
FileZilla FTP Server Multiple DoS	4	4	16	High
FileZilla < 0.9.31 DoS	3	4	12	Medium
RDP Weak SSL (SWEET32)	4	5	20	High
TLS 1.0 Support (Deprecated)	3	4	12	Medium
PHP Outdated (ver. 7.3.21)	2	3	6	Medium

Key:

- Likelihood = How easily exploitable the vulnerability is (1 = very unlikely, 5 = highly likely).
- Impact = How damaging it would be if exploited (1 = minimal, 5 = severe).
- Severity Coding:
 - Red = High risk (15 – 25)
 - Yellow = Medium risk (5 – 14)
 - Green = Low risk (1 – 4)

Justification for Likelihood and Impact Scores

FileZilla FTP Server Multiple DoS Vulnerabilities (CVE-2005-0851)

Likelihood = 4 (High)

This has been categorized as high because threats actors can send a filename like “CON” (a reserved name) or enable MODE Z compression which can slow down the service. These conditions only require basic FTP client access and knowledge of the vulnerability. Anonymous FTP connections are possible; no authentication is really needed.

The system is exposed as it was detected externally, which confirms the port is live and exploitable. Threat actors may be motivated by the desire to disrupt services by crashing or slowing down the server, which could serve as a diversion from a more serious attack.

Impact = 4 (High)

The impact has been categorized as high because exploitation of this vulnerability causes full denial of FTP services, blocking file transfer operations. This affects availability in the CIA triad. This can also affect the organization’s reputation as users who cannot access files may express frustration and question reliability.

If the server houses critical file transfers (e.g., customer data or backups), downtime translates to missed deadlines or decreased productivity. As for compliance issues, ISO 27001 Annex A.17 (business continuity) and NIST CSF “Recover” both stress maintaining service availability – repeated outages display weak security and resilience.

Source

(VulDB, 2015)

FileZilla Server < 0.9.31 DoS (CVE-2009-0884)

Likelihood = 3 (Medium)

The likelihood is rated as medium because this vulnerability is exploited by crafting a malformed SSL/TLS packet which is more technical than the previous vulnerability but still well-documented publicly. No logon is required, only a TCP connection to the FTPS port.

The old FileZilla version is currently still active which confirms system exposure. As for threat actor motivations, DoS attacks on encrypted channels are less common than brute-force or ransomware, so fewer attackers will try this.

Impact = 4 (High)

A successful attack on the server crashes the entirety of FileZilla processes, taking the FTP offline. Users reliant on FTPS connections may lose trust if the service is repeatedly down.

There could be financial loss if automated jobs fail, leading to costly recovery steps. NIST's CSF "Protect" category highlights the use of patch management; failure to patch known SSL bugs is a compliance and audit finding.

Source

(National Institute of Technology and Standards, 2024b)

RPD Weak SSL Cipher – SWEET32 (CVE-2016-2183)

Likelihood = 4 (High)

The likelihood is high because SWEET32 requires traffic capture and large volumes of encrypted data which is convenient because RDP sessions are the kind of long-lived streams the attack was designed for. Public proof of concepts (PoCs) and attacker playbooks exist. Only

man-in-the-middle (MITM) access is needed – attackers who compromise corporate Wi-Fi, gateway, or cloud peering could attempt it.

Evidence of system exposure was found. An RDP port was found open externally; RDP is said to be one of the most attacked protocols globally. A threat actor can be motivated by domain admin credentials which can be yielded from RDP access, making it a high-value target.

Impact = 5 (Critical)

This vulnerability could allow attackers to steal credentials in which they could disable services. An RDP breach often could lead to ransomware outbreaks, which become public and damage trust.

This could impact the organization financially including incident response, ransom payouts, and downtime. In consensus, an average ransomware incident could exceed six figures. Within all compliance standards, PCI DSS, HIPAA, and ISO 27001 all mandate strong encryption. Using weak 3DES ciphers fails compliance tests.

Source

(National Institute of Technology and Standards, 2016)

TLS 1.0 Protocol Support (Deprecated)

Likelihood = 3 (Medium)

TLS 1.0 is not immediately exploitable, but it allows downgrade attacks and has known weaknesses. To exploit this vulnerability, the attacker needs to be on-path or control a client/server that negotiates the weaker protocol.

This vulnerability has been detected running on RDP - if externally reachable, attackers could force weaker connections. Attackers may be motivated more primarily by compliance bypass or enabling easier MITM rather than immediate RDP brute force.

Impact = 4 (High)

There is no disruption of services, but confidentiality and integrity of sessions are weakened. This can also damage the reputation of the organization because use of deprecated encryption protocols is seen as negligent, especially if exposed to clients.

Financial loss can be experienced since PCI DSS banned TLS 1.0 in 2018 and can issue fines or penalties if violated. Also, ISO 27001 controls require use of strong cryptography methods.

Source

(Moriarty & Farrell, 2021b)

PHP 7.3.21 Outdated (CVE-2020-7069 / 7070)

Likelihood = 2 (Low/Medium)

This specific vulnerability (AES-CCM IV misuse) requires custom crypto code using “openssl_encrypt()”. Not all apps use this path.

AES-CCM IV ensures that even if the same plaintext is encrypted multiple times with the same key, the resulting ciphertext and authentication tag will be different each time.

AES-CCM IV misuse is a critical vulnerability that leads to a loss of both confidentiality and integrity. The nonce (number used once) must be unique for every message encrypted with the same key. Reusing a nonce exposes the encryption to several damaging attacks (Housley, 2007).

To exploit this vulnerability, the attacker must reach a PHP application that invokes AES-CCM, limiting the scope. Evidence of exposure shows that the service is internet-accessible on TCP/80, which raises baseline risk of scanning/exploitation. Attackers prefer RCE or SQLi than crypto bugs, so motivation is lower.

Impact = 3 (Moderate)

If exploited, there will be no service disruption – the cryptography flaw does not crash PHP. Running an unsupported PHP version indicates poor patch hygiene, which reduces customer confidence.

This vulnerability could introduce financial loss if sensitive encrypted data (tokens, credentials) is mishandled – breaches could follow incurring costs. Outdated software violates patch management controls in ISO 27001 and NIST CSF’s “Protect” function.

Source

(Red Hat Security Advisory, 2021)

Asset-Based Summary

It can be discerned that the two most critical assets determined from the risk matrix are:

1. Windows host (10.13.30.105) running RDP with weak SSL (SWEET32) – Risk Score 20
2. Windows host (10.13.30.105) running FileZilla FTP vulnerable to multiple DoS – Risk Score 16

This means that the Windows server at 10.13.30.105 is the most vulnerable and highest priority asset to secure.

Asset Name	Asset Classification	Severity	Applicable Frameworks	Compliance Impact
Windows Server - RDP Service (10.13.30.105)	Digital	High	NIST CSF, ISO 27001	Outdated TLS (1.0/1.1) and weak ciphers (3DES) violate modern encryption standards. Non-compliance with PCI DSS and ISO 27001 for strong encryption may lead to regulatory issues and increased breach likelihood.
Windows Server – FileZilla FTP (10.13.30.105)	Digital	High	NIST CSF, ISO 27001	FTP DoS flaws affect availability. A DoS attack could disrupt business operations, violating ISO 27001 requirements for availability and resilience. Retaining legacy, insecure FTP also increases audit findings and risk of compliance gaps.

References

- Bhargavan, K., & Leurent, G. (n.d.). *Sweet32: Birthday attacks on 64-bit block ciphers in TLS and OpenVPN*. Sweet32.Info. <https://sweet32.info>
- Common Vulnerabilities and Exposures. (2016, September 1). *CVE-2016-2183*. Wwww.cve.org. <https://www.cve.org/CVERecord?id=CVE-2016-2183>
- Common Vulnerabilities and Exposures. (2017, January 31). *CVE-2016-6329*. Cve.org. <https://www.cve.org/CVERecord?id=CVE-2016-6329>
- Housley, R. (2007, November). *RFC 5084: Using AES-CCM and AES-GCM Authenticated Encryption in the Cryptographic Message Syntax (CMS)*. IETF Datatracker. <https://datatracker.ietf.org/doc/html/rfc5084>
- Moriarty, K., & Farrell, S. (2021a, January). *Deprecating TLS 1.0 and TLS 1.1*. IETF Datatracker. <https://datatracker.ietf.org/doc/html/draft-ietf-tls-oldversions-deprecate>
- Moriarty, K., & Farrell, S. (2021b, March). *RFC 8996: Deprecating TLS 1.0 and TLS 1.1*. Wwww.rfc-Editor.org. <https://www.rfc-editor.org/rfc/rfc8996>
- National Institute of Technology and Standards. (2016, August 31). *NVD - CVE-2016-2183*. Nvd.nist.gov. <https://nvd.nist.gov/vuln/detail/CVE-2016-2183>
- National Institute of Technology and Standards. (2020a). *NVD - CVE-2020-7069*. Nist.gov. <https://nvd.nist.gov/vuln/detail/CVE-2020-7069>
- National Institute of Technology and Standards. (2020b). *NVD - CVE-2020-7070*. Nist.gov. <https://nvd.nist.gov/vuln/detail/CVE-2020-7070>

National Institute of Technology and Standards. (2024a). *NVD - CVE-2005-0851*. Nist.gov.

<https://nvd.nist.gov/vuln/detail/CVE-2005-0851>

National Institute of Technology and Standards. (2024b). *NVD - CVE-2009-0884*. Nist.gov.

<https://nvd.nist.gov/vuln/detail/CVE-2009-0884>

Red Hat Security Advisory. (2021, September 11). *RHSA-2021:4213 - Security Advisory*.

Redhat.com. <https://access.redhat.com/errata/RHSA-2021:4213>

VulDB. (2015, March 10). *Filezilla Server up to 0.9.5 File Upload infinite loop*. VulDB.

<https://vuldb.com/?id.24670>